

SIMATS ENGINEERING (SAVEETHA SCHOOL OF ENGINEERING)
Department of Computer Science and Engineering
ASSESSMENT TOOL 2 – INCIDENT ANALYSIS (ROOT CAUSE & RISK)

Course Code:	CSA5803	Course Title:	DEVSECOPS ENGINEERING AND APPLICATION SECURITY
CO Assessed:	CO5 – Precision (BL1, BL2, BL3)	Assessment:	Assessment Tool 2
Weightage:	30% of CIA	Total Marks:	100
CO5 Statement:	Incident Investigation, Root Cause Analysis and Risk Assessment.		
Student Name:	M.GOKUL	Reg. No.:	192565067
Section / Batch:	2025 / B-TECH (CSE)	Date:	27/08/2026

Instructions to Students

- Review the given security incident scenario, evidence, logs and indicators carefully before beginning the analysis.
- Identify the incident sequence, affected assets, relevant indicators and supporting evidence without making unsupported assumptions.
- Determine the root cause by linking observed events, vulnerabilities and contributing conditions in a logical sequence.
- Assess identified risks based on likelihood, severity and potential technical or operational impact.
- Present investigation findings, root-cause reasoning and risk assessment clearly with appropriate technical justification.

Question Type	Focus Area	Questions	Marks
INCIDENT ANALYSIS	Investigation & Risk	Q1	Q1 – 100
GRAND TOTAL:		100 Marks	

INCIDENT INVESTIGATION, ROOT CAUSE ANALYSIS AND RISK ASSESSMENT FOR A CLOUD STORAGE SECURITY INCIDENT

Course Code: CSA5803

Course Title: DevSecOps Engineering and Application Security

CO5: Incident Investigation, Root Cause Analysis and Risk Assessment

1. INTRODUCTION

Cloud storage has become an essential part of modern organizations because it provides scalable storage, remote access, collaboration, backup capabilities, and reduced infrastructure costs. Organizations store a large amount of business-critical and sensitive information in cloud environments, including customer information, financial documents, project files, intellectual property, software source code, employee records, and confidential business data. Although cloud platforms provide strong security capabilities, the security of cloud-stored data still depends heavily on proper identity management, access control, monitoring, and incident response.

The incident scenario under consideration involves **cloud-storage alerts showing mass file downloads followed by deletion attempts from one account**. This activity is highly suspicious because it indicates an abnormal sequence of events. A legitimate user may occasionally download a large number of files or delete files as part of normal work. However, when a single account performs a sudden large-scale download and is then followed by deletion attempts, the possibility of a security incident becomes significant.

The suspicious sequence may indicate that an attacker has gained access to a legitimate account and is attempting to copy sensitive information before destroying or removing the original files. It may also indicate malicious insider activity, misuse of excessive privileges, compromised API credentials, or automated malicious activity. Therefore, the incident must be investigated carefully using available evidence and logs before making a final conclusion.

The assessment requirements emphasize the need to identify the incident sequence, affected assets, indicators, supporting evidence, root cause, vulnerabilities, contributing conditions, and associated risks. The investigation should avoid unsupported assumptions and should clearly link the observed events with possible security weaknesses and business impacts.

The main objectives of this incident investigation are:

1. To analyze the sequence of suspicious events.
2. To identify the affected cloud assets.
3. To identify indicators of compromise and supporting evidence.
4. To develop a complete incident response plan.
5. To determine possible root causes and contributing factors.
6. To assess the risks associated with the incident.
7. To recommend appropriate mitigation strategies.
8. To justify the use of MFA, object versioning, DLP, and anomaly detection.
9. To propose improvements that can prevent similar incidents in the future.

This report provides a structured and detailed incident analysis based on the principles of incident investigation, root cause analysis, risk assessment, containment, eradication, recovery, and continuous improvement.

2. INCIDENT SCENARIO

The cloud security monitoring system generated alerts showing that a single user account performed an unusually large number of file downloads from the organization's cloud storage environment. After the mass download activity, the same account began attempting to delete files.

The sequence can be represented as follows:

Normal Account Access → Unusual Mass File Downloads → Security Alert → Deletion Attempts → Potential Data Theft and Data Loss Risk

This activity should be classified as a potentially serious security incident because it combines two dangerous actions:

- **Mass data extraction**
- **Potential destruction of original data**

The mass download may indicate that data was copied outside the organization's control. The deletion attempts may indicate an effort to disrupt business operations, destroy evidence, damage organizational data, or increase the impact of the attack.

However, it is important that the investigation does not immediately assume that the account was compromised. The investigation should examine all available evidence. Possible explanations include:

- Compromised user credentials.
- Insider misuse.
- Stolen authentication tokens.
- Malicious API usage.
- An automated script or application error.
- Excessive permissions.
- A legitimate bulk migration activity that was not properly documented.
- A user accidentally performing bulk operations.

The purpose of the investigation is therefore to determine which explanation is supported by the available evidence.

3. INITIAL INCIDENT ANALYSIS

The initial analysis begins by reviewing the suspicious sequence of events. The security team should collect and preserve evidence from the cloud environment before making major changes to the affected systems.

The first observation is that one account downloaded an unusually large number of files. This behavior is suspicious when the download volume is significantly higher than the normal behavior of the account. For example, if the account normally accesses ten or twenty files per day but suddenly downloads thousands of files within a short period, the activity should be considered anomalous.

The second observation is the deletion attempt. The timing of the deletion activity is important. When deletion follows a large-scale download, the combined pattern may indicate a possible attack sequence:

1. Gain access to the account.
2. Identify valuable files.
3. Download or copy the files.
4. Attempt to delete the original files.
5. Cause data loss or operational disruption.

The investigation should identify the exact timeline of events. The following questions should be answered:

- When did the account first log in?
- From which IP address was the account accessed?
- Was the login location normal for the user?

- What device was used?
- Was a new browser or device involved?
- How many files were downloaded?
- Which files were downloaded?
- Were the files sensitive or confidential?
- How quickly were the files downloaded?
- When did the deletion attempts begin?
- Which files were targeted for deletion?
- Were any deletion attempts successful?
- Were permissions changed before or after the activity?
- Were new API keys or access tokens created?
- Did the account perform any other suspicious activity?

Answering these questions helps establish the complete incident sequence.

4. INCIDENT SEQUENCE AND TIMELINE

A detailed timeline is necessary for determining how the incident occurred. The incident sequence may be divided into several stages.

4.1 Stage 1: Account Access

The affected cloud account was used to access the cloud storage environment. The investigation should determine whether the login was performed by the legitimate account owner or by an unauthorized person. Important evidence includes:

- Login timestamp.
- Source IP address.
- Geographic location.
- Device identifier.
- Browser information.
- Authentication method.
- Failed login attempts before successful login.
- MFA status.
- Session creation information.

If the login came from an unknown location, unfamiliar device, or suspicious IP address, the likelihood of account compromise increases.

4.2 Stage 2: File Enumeration and Access

Before downloading files, an attacker or user may list folders and objects to identify valuable information. The investigation should review whether the account accessed an unusually large number of directories or file listings.

Suspicious behavior may include:

- Listing large numbers of files.
- Accessing folders outside the user's normal department.
- Searching for sensitive documents.
- Accessing confidential storage areas.
- Attempting to access restricted data.

This stage can help determine whether the activity was targeted or random.

4.3 Stage 3: Mass File Download

The account then performed a large number of downloads. This is a major indicator of possible data

exfiltration.

The investigation should identify:

- Total number of downloaded files.
- Total amount of data downloaded.
- Types of files accessed.
- Sensitivity of the files.
- Download speed.
- Download duration.
- Download destination if known.
- Whether downloads occurred through a browser, application, or API.

Mass downloads can cause serious consequences because the organization may lose control of sensitive information even if the original files remain in the cloud environment.

4.4 Stage 4: Deletion Attempts

After the downloads, the account attempted to delete files. This creates a direct risk to data availability.

The investigation should determine:

- Which objects were targeted.
- Whether the deletion attempts succeeded.
- Whether object versioning was enabled.
- Whether deleted objects can be recovered.
- Whether backups exist.
- Whether deletion actions were manual or automated.
- Whether the account attempted to delete multiple versions.
- Whether recovery settings were changed.

If deletion attempts were successful and no recovery controls exist, the organization could suffer permanent data loss.

5. AFFECTED ASSETS

The incident may affect several categories of organizational assets.

5.1 User Account

The affected account is the primary identity involved in the incident. It must be investigated to determine whether it was:

- Compromised.
 - Misused by the legitimate user.
 - Accessed using stolen credentials.
 - Accessed using a stolen token.
 - Used by a malicious application.
-

5.2 Cloud Storage Resources

The cloud storage environment may contain the files targeted by the suspicious activity. These resources may include:

- Storage buckets.
- Containers.
- Folders.
- Objects.
- Shared drives.
- Backup repositories.

5.3 Sensitive Organizational Data

The downloaded data may contain:

- Customer information.
- Financial records.
- Employee information.
- Source code.
- Research data.
- Business documents.
- Intellectual property.
- Security configuration files.

The sensitivity of the downloaded data directly affects the severity of the incident.

5.4 Authentication Credentials

Credentials may have been exposed or stolen. These may include:

- Passwords.
- MFA recovery codes.
- API keys.
- Access tokens.
- Session cookies.
- OAuth tokens.

If credentials were compromised, other systems using the same identity may also be at risk.

5.5 Cloud Permissions and Roles

Excessive privileges may have contributed to the incident. If the affected account had permission to download and delete a large amount of data, the impact of a compromised account would be significantly greater.

5.6 Organizational Reputation and Business Operations

Although these are not technical assets in the same way as files or accounts, they may also be affected. A major data breach or data-loss event can cause:

- Customer distrust.
 - Legal consequences.
 - Financial loss.
 - Operational downtime.
 - Reputation damage.
-

6. INDICATORS OF COMPROMISE AND SUPPORTING EVIDENCE

The following indicators should be examined during the investigation.

6.1 Unusual Download Volume

A sudden increase in the number or size of downloaded files is one of the strongest indicators of suspicious behavior.

For example, a user who normally downloads 100 MB per day but suddenly downloads 100 GB should trigger a security investigation.

6.2 Unusual Login Location

The account may have been accessed from an unfamiliar country, city, or network. Geographic anomalies

may indicate credential theft.

6.3 New or Unrecognized Device

A new device may not always indicate an attack, but it becomes more suspicious when combined with mass downloads and deletion attempts.

6.4 Unusual Access Time

Access during unusual hours may indicate suspicious activity, particularly if the account is normally used only during regular business hours.

6.5 Failed Login Attempts

Multiple failed login attempts followed by a successful login may indicate:

- Password guessing.
 - Credential stuffing.
 - Unauthorized access attempts.
-

6.6 Bulk Deletion Activity

Deletion of many objects in a short period may indicate:

- Malicious activity.
 - Ransomware behavior.
 - Insider sabotage.
 - Automated scripts.
-

6.7 Permission Changes

Changes to cloud permissions should be examined because an attacker may first increase privileges before downloading or deleting data.

6.8 API Anomalies

Unexpected API requests, unusual automation tools, or new API credentials may indicate programmatic abuse.

7. INCIDENT RESPONSE PLAN

A structured incident response plan should be followed to minimize damage and recover affected systems. The plan can be divided into six major phases:

1. Preparation
 2. Identification
 3. Containment
 4. Eradication
 5. Recovery
 6. Post-Incident Review
-

8. PHASE 1: PREPARATION

Preparation is essential because organizations should not wait for an attack to occur before creating security controls.

The organization should establish:

- An incident response team.
- Defined roles and responsibilities.
- Cloud logging.
- Centralized monitoring.
- Security alerting.
- Backup procedures.
- Object versioning.
- MFA.
- DLP policies.
- Anomaly detection systems.
- Communication procedures.

The incident response team may include:

- Incident Response Manager
- Cloud Security Engineer
- Security Analyst
- System Administrator
- Forensic Investigator
- Legal and Compliance Team
- Management Representative

Preparation also requires documentation. The organization should maintain:

- Incident response procedures.
 - Escalation procedures.
 - Contact information.
 - Cloud asset inventory.
 - Data classification policies.
 - Recovery procedures.
-

9. PHASE 2: IDENTIFICATION

The identification phase begins when the security monitoring system detects unusual activity.

The security team should first validate the alert and determine whether it represents a real security incident.

The following evidence should be collected:

- Cloud audit logs.
- Authentication logs.
- Access logs.
- File download logs.
- Deletion logs.
- API logs.
- Network information.
- Account permission history.

The team should establish a detailed timeline.

A possible timeline format is:

Time Event	Evidence
------------	----------

T1	Account login	Authentication logs
T2	File enumeration	Cloud audit logs
T3	Mass downloads begin	Storage access logs
T4	Security alert generated	Monitoring system
T5	Deletion attempts begin	Object deletion logs
T6	Incident response initiated	Security incident record

The incident should then be assigned a severity level.

Because the event involves both possible data exfiltration and possible data destruction, it should generally be treated as a **high-severity or critical incident**, depending on the sensitivity of the affected data.

10. PHASE 3: CONTAINMENT

Containment aims to stop the suspicious activity from continuing.

The first immediate action should be to prevent additional unauthorized access.

Recommended actions include:

1. Temporarily suspend or restrict the affected account.
2. Revoke all active sessions.
3. Invalidate access tokens.
4. Rotate or revoke API keys.
5. Reset the account password.
6. Block suspicious source IP addresses where appropriate.
7. Prevent further deletion of critical objects.
8. Preserve evidence.

A key principle is that the organization should preserve evidence before making unnecessary changes.

Logs may be required for forensic investigation.

The affected account should not immediately be deleted because:

- It may contain important evidence.
- Deleting it may destroy audit information.
- The organization must first understand the scope of the compromise.

Temporary containment may include restricting the account to minimal access rather than permanently removing it.

11. PHASE 4: ERADICATION

Eradication focuses on removing the cause of the incident.

The organization should investigate whether the root cause was:

- Stolen credentials.
- Phishing.
- Malware.
- Insider misuse.
- Excessive privileges.
- Exposed API keys.
- Misconfigured cloud access.
- Weak authentication.

Once the cause is identified, corrective actions should be taken.

Examples include:

- Removing unauthorized API keys.

- Revoking compromised tokens.
- Rebuilding compromised devices.
- Removing malicious software.
- Resetting credentials.
- Enforcing MFA.
- Correcting excessive permissions.
- Disabling unnecessary accounts.
- Updating security configurations.

The organization should also check whether the attacker created persistence mechanisms, such as:

- Additional user accounts.
 - New access keys.
 - Modified permissions.
 - Scheduled automated tasks.
-

12. PHASE 5: RECOVERY

Recovery focuses on restoring normal and secure operations.

The organization should:

- Restore deleted files.
- Recover earlier object versions.
- Restore data from secure backups.
- Re-enable accounts only after verification.
- Verify cloud permissions.
- Monitor the environment closely.

Recovery should be performed carefully. Restoring a compromised configuration without verification may reintroduce the security problem.

The security team should verify:

- Data integrity.
- Data availability.
- User access.
- Application functionality.
- Security configuration.

After recovery, enhanced monitoring should continue for a defined period.

13. PHASE 6: POST-INCIDENT REVIEW

After the incident is resolved, the organization should conduct a detailed review.

The review should include:

- What happened?
- When did it happen?
- How was the incident detected?
- What data was affected?
- Was data stolen?
- Was data deleted?
- What was the root cause?
- Which security controls failed?
- Which controls worked?
- How can future incidents be prevented?

A final incident report should document:

1. Incident description.
 2. Timeline.
 3. Affected assets.
 4. Evidence.
 5. Root cause.
 6. Impact.
 7. Risk assessment.
 8. Response actions.
 9. Recovery actions.
 10. Recommendations.
-

14. ROOT CAUSE ANALYSIS

Root cause analysis is important because simply stopping the immediate activity is not sufficient. The organization must understand why the incident was possible.

14.1 Possible Root Cause: Compromised Credentials

One possible root cause is that the user's credentials were stolen through phishing, password reuse, credential stuffing, or another form of credential compromise.

If the attacker successfully obtained the user's password and MFA was not enabled, the attacker could access the cloud account and use its permissions.

The sequence would be:

Credential Theft → Account Login → Mass Download → Deletion Attempts

14.2 Possible Root Cause: Lack of MFA

If the organization relied only on passwords, a stolen password could provide direct access to the cloud account.

The lack of MFA would therefore increase the probability of account takeover.

14.3 Possible Root Cause: Excessive Privileges

The affected account may have had permissions beyond what was necessary.

For example, a normal user may only need permission to:

- View files.
- Upload files.
- Modify selected documents.

However, if the same account had broad deletion permissions, the potential impact would be much greater. This demonstrates the importance of the **principle of least privilege**.

14.4 Possible Root Cause: Insufficient Monitoring

The suspicious activity may have continued because the organization did not have adequate monitoring or anomaly detection.

If the system did not detect abnormal download volume quickly, the attacker could continue copying data.

14.5 Possible Root Cause: Lack of DLP

Without Data Loss Prevention controls, the organization may not have been able to detect or restrict the movement of sensitive information.

14.6 Possible Root Cause: Lack of Object Versioning

If object versioning was disabled, deleted files could be permanently lost.
This would increase the impact of the deletion attempts.

15. ROOT CAUSE LOGICAL SEQUENCE

A logical sequence linking vulnerabilities and observed events can be represented as follows:

Weak Authentication or Stolen Credentials

↓

Unauthorized Access to Legitimate Cloud Account

↓

Excessive Account Permissions

↓

Access to Large Number of Files

↓

Mass File Download

↓

Potential Data Exfiltration

↓

Deletion Attempts

↓

Risk of Data Loss and Business Disruption

This sequence demonstrates how multiple security weaknesses can combine to create a serious incident. The exact root cause should be determined only after examining evidence. The investigation should not claim that the account was compromised unless logs and supporting evidence confirm that conclusion.

16. RISK ASSESSMENT

Risk assessment evaluates the likelihood and impact of the identified threats.

The assessment should consider:

- Likelihood of occurrence.
 - Technical impact.
 - Operational impact.
 - Financial impact.
 - Legal impact.
 - Reputational impact.
-

16.1 Risk: Data Exfiltration

Likelihood: High

Impact: High

Severity: Critical

Mass downloads create a serious possibility that confidential information has been copied outside the organization.

Potential consequences include:

- Data breaches.
- Intellectual property theft.
- Privacy violations.
- Competitive damage.

- Legal penalties.

16.2 Risk: Data Destruction

Likelihood: Medium to High

Impact: High

Severity: High

Deletion attempts may result in:

- Loss of important documents.
- Application failures.
- Business interruption.
- Recovery costs.

16.3 Risk: Account Compromise

Likelihood: High

Impact: High

Severity: Critical

If one account has been compromised, other accounts may also be at risk, especially if passwords are reused or similar authentication methods are used.

16.4 Risk: Operational Disruption

Likelihood: Medium

Impact: High

Severity: High

If important files are deleted, employees may not be able to perform their work, and cloud-based applications may fail.

16.5 Risk: Reputation Damage

Likelihood: High

Impact: High

Severity: High

Customers and business partners may lose trust if sensitive data is exposed or important services become unavailable.

17. RISK MATRIX

Risk	Likelihood	Impact	Overall Severity
Sensitive data theft	High	High	Critical
Account compromise	High	High	Critical
File deletion	Medium/High	High	High
Business disruption	Medium	High	High
Compliance violation	Medium/High	High	High
Reputation damage	High	High	High
Financial loss	Medium	High	High

The highest-priority risks are data theft and account compromise because the suspicious activity already includes mass file downloads from one account.

18. MITIGATION STRATEGY: MULTI-FACTOR AUTHENTICATION

Multi-Factor Authentication, commonly known as MFA, should be mandatory for cloud accounts. MFA requires users to provide more than one form of authentication.

For example:

1. Something the user knows, such as a password.
2. Something the user possesses, such as an authentication application or security key.

A password alone is vulnerable to:

- Phishing.
- Password reuse.
- Credential leaks.
- Brute-force attacks.
- Credential stuffing.

MFA provides an additional security layer.

If an attacker steals a password, the attacker may still be unable to access the account without the second authentication factor.

Therefore, MFA directly reduces the likelihood of unauthorized account access.

Justification for MFA

MFA is justified because the incident may have started with account compromise. The suspicious actions were performed through a legitimate account. Strong authentication can reduce the chance that stolen credentials are sufficient for access.

The benefits of MFA include:

- Reduces account takeover risk.
- Protects against stolen passwords.
- Improves cloud account security.
- Reduces the success of credential-based attacks.
- Provides stronger identity verification.

MFA should be particularly important for:

- Administrators.
- Users with access to sensitive data.
- Users with deletion privileges.
- Users with cloud management permissions.

19. MITIGATION STRATEGY: OBJECT VERSIONING

Object versioning stores multiple versions of cloud storage objects.

For example:

- Version 1: Original document.
- Version 2: Modified document.
- Version 3: Latest document.

If an object is deleted or changed, an earlier version may still be available.

Object versioning is especially important in this incident because the account attempted to delete files.

Without versioning, malicious or accidental deletion can result in permanent data loss.

With versioning enabled, administrators may be able to restore an earlier version.

Justification for Object Versioning

Object versioning provides:

- Protection against accidental deletion.
- Protection against malicious deletion.

- Ability to recover previous versions.
- Improved incident recovery.
- Improved data resilience.

In this incident, even if the attacker successfully deleted files, object versioning could reduce the damage by allowing the organization to restore the affected objects.

Therefore, object versioning is an important security and recovery control.

20. MITIGATION STRATEGY: DATA LOSS PREVENTION

Data Loss Prevention, or DLP, is designed to detect, monitor, and control the movement of sensitive information.

A DLP system can identify sensitive information such as:

- Personal information.
- Customer records.
- Financial information.
- Confidential business documents.
- Source code.
- Credentials.
- Security secrets.

DLP policies can detect unusual data movement and may:

- Generate alerts.
- Block downloads.
- Restrict external sharing.
- Require additional approval.
- Apply security policies.

Justification for DLP

The primary suspicious action in the incident was mass file downloading.

DLP is therefore highly relevant because it can monitor data movement and identify abnormal attempts to transfer large amounts of sensitive information.

For example, a DLP policy could identify:

- A large number of confidential files downloaded in a short period.
- A large amount of data transferred to an unknown location.
- Unauthorized access to restricted information.

The system can then alert security teams or automatically restrict the activity.

DLP therefore helps reduce the risk of data exfiltration.

21. MITIGATION STRATEGY: ANOMALY DETECTION

Anomaly detection identifies activities that are significantly different from normal behavior.

The system can create a baseline of normal user activity.

For example, a user may normally:

- Download 10 files per day.
- Access files between 9 AM and 6 PM.
- Use one known device.
- Connect from one normal location.

If the user suddenly:

- Downloads thousands of files.
- Logs in from a new country.

- Uses an unknown device.
- Performs large deletion operations.

the system can classify the behavior as anomalous.

Justification for Anomaly Detection

Anomaly detection is particularly important because the incident involves unusual behavior from an apparently legitimate account.

Traditional security controls may allow an attacker to operate successfully if the attacker uses valid credentials.

Anomaly detection focuses not only on identity but also on behavior.

It can identify:

- Abnormal download volume.
- Unusual login time.
- New device usage.
- Unusual geographic access.
- Sudden deletion activity.
- Unusual API behavior.

This provides early detection of account misuse.

22. COMBINED SECURITY ARCHITECTURE

The strongest protection is achieved by combining multiple controls.

The recommended defense sequence is:

MFA

Prevents or reduces unauthorized account access.

↓

Least Privilege

Limits the permissions available to an account.

↓

DLP

Monitors and controls sensitive data movement.

↓

Anomaly Detection

Identifies unusual user behavior.

↓

Object Versioning and Backups

Protect against permanent data loss.

↓

Centralized Logging and Incident Response

Supports rapid detection and investigation.

No single security control is sufficient.

For example:

- MFA cannot recover deleted files.
- Object versioning cannot prevent account compromise.
- DLP may not stop all attacks.
- Anomaly detection may generate false alerts.

Therefore, a defense-in-depth approach is necessary.

23. LEAST PRIVILEGE AS A MITIGATION STRATEGY

The principle of least privilege means that a user should receive only the minimum permissions required to perform assigned tasks.

For example:

A normal employee may require permission to:

- Read documents.
- Upload assigned files.
- Modify selected documents.

The employee may not require permission to:

- Delete all organizational data.
- Change security configurations.
- Access confidential information from unrelated departments.

By reducing unnecessary permissions, the organization reduces the potential impact of account compromise.

If a low-privileged account is compromised, the attacker should have limited access.

This principle is essential because the affected account in the incident was able to perform both large-scale downloads and deletion attempts.

24. CONTINUOUS CLOUD MONITORING

Cloud monitoring should continuously collect information about:

- User authentication.
- File access.
- Data downloads.
- Deletion activity.
- Permission changes.
- API requests.
- Administrative actions.

Logs should be centralized and protected from unauthorized modification.

The monitoring system should generate alerts for:

- Excessive downloads.
- Bulk deletion.
- Unusual geographic access.
- New devices.
- Impossible travel patterns.
- Privilege escalation.
- Suspicious API usage.

Rapid detection is important because the earlier an incident is identified, the less opportunity an attacker has to cause damage.

25. DATA BACKUP AND RECOVERY

In addition to object versioning, organizations should maintain secure backups.

Backups should be:

- Regularly created.
- Protected from unauthorized deletion.
- Tested for recovery.
- Stored separately from primary production data.

The organization should periodically test restoration procedures.
A backup is useful only if the organization can successfully restore data when required.
In this incident, backups provide an additional layer of protection if deletion attempts are successful.

26. INCIDENT COMMUNICATION PLAN

Communication during an incident should be controlled and documented.

The security team should inform:

- Incident response team.
- Security management.
- System administrators.
- Cloud administrators.
- Legal and compliance teams, when necessary.
- Senior management.

Sensitive incident information should not be shared publicly without authorization.

The communication plan should include:

- Incident severity.
- Current impact.
- Actions taken.
- Systems affected.
- Recovery status.
- Required decisions.

A clear communication process reduces confusion during a major incident.

27. FORENSIC INVESTIGATION

The forensic investigation should preserve and analyze evidence.

Important evidence includes:

- Authentication logs.
- Cloud audit logs.
- Access logs.
- API activity.
- IP addresses.
- Device identifiers.
- File access history.
- Deletion records.
- Permission changes.

Evidence should be preserved carefully.

The investigation should avoid unnecessary changes to logs or affected systems.

The forensic team should answer:

- Who accessed the account?
- When was it accessed?
- From where?
- What files were accessed?
- What data was downloaded?
- Were files successfully deleted?
- How did the unauthorized activity begin?
- Was the account compromised?

The final conclusion should be based on evidence rather than assumptions.

28. LONG-TERM PREVENTION STRATEGY

To prevent similar incidents, the organization should implement the following long-term measures.

28.1 Mandatory MFA

All cloud users should use MFA, especially administrators and users with sensitive permissions.

28.2 Least Privilege

Permissions should be reviewed regularly.

28.3 Privileged Access Monitoring

High-privilege accounts should receive additional monitoring.

28.4 DLP Policies

Sensitive information should be identified and protected.

28.5 Anomaly Detection

User behavior should be continuously analyzed.

28.6 Object Versioning

Critical cloud objects should use versioning.

28.7 Secure Backups

Independent backups should be maintained and tested.

28.8 Centralized Logging

Cloud logs should be collected and protected.

28.9 Security Awareness Training

Users should be trained to recognize phishing and credential theft attempts.

28.10 Regular Incident Response Testing

The organization should conduct incident response exercises to test preparedness.

29. OVERALL FINDINGS

The security alerts indicate a serious and potentially high-impact cloud security incident.

The most important observed behavior is:

Mass File Downloads + Deletion Attempts from One Account

This combination creates two major security concerns:

1. **Confidentiality Risk:** The files may have been copied outside the organization.
2. **Availability Risk:** The original files may have been deleted or damaged.

The investigation must determine whether the account activity was caused by:

- External compromise.
- Insider misuse.

- Stolen credentials.
- Malicious automation.
- Misconfiguration.
- Legitimate but unusual business activity.

The exact cause should only be confirmed after examining supporting evidence.

30. CONCLUSION

The incident involving mass cloud-storage downloads followed by deletion attempts from one account should be treated as a potentially serious security event. The sequence of actions may indicate data exfiltration followed by an attempt to cause data loss or business disruption. However, a proper investigation is required before concluding that the account was compromised.

The incident response process should include identification, evidence collection, containment, eradication, recovery, and post-incident review. Immediate actions should focus on restricting the affected account, revoking suspicious sessions and tokens, preserving logs, preventing additional deletion, and determining the scope of the incident.

The root cause analysis should investigate compromised credentials, lack of MFA, excessive privileges, insufficient monitoring, missing DLP controls, and weak recovery mechanisms. The final root cause should be supported by authentication logs, cloud audit records, access records, and other evidence. Risk assessment shows that the incident may result in critical consequences, including sensitive data theft, permanent data loss, account compromise, business disruption, financial loss, legal consequences, and reputational damage.

The recommended security strategy should use multiple layers of protection.

MFA is justified because it reduces the risk of account takeover when passwords are stolen.

Object versioning is justified because it allows recovery from malicious or accidental deletion.

DLP is justified because it helps detect and control unauthorized movement of sensitive data.

Anomaly detection is justified because it can identify unusual behavior such as sudden mass downloads and bulk deletion attempts.

In addition, the organization should implement least privilege, secure backups, centralized logging, continuous monitoring, strong access controls, and regular incident response testing.

Overall, the best solution is a **defense-in-depth approach** in which authentication, authorization, monitoring, data protection, anomaly detection, backup, and incident response work together. By implementing these controls, the organization can reduce the likelihood of similar incidents and minimize the technical and business impact if an incident occurs in the future.

.